Informe de Ética y Ciberseguridad

Sesión 8 — Cumplimiento normativo y verificación de seguridad básica

Alumno(a)	Proyecto / Negocio
JAVIER RODRIGO CALCÍN PAJA	CARD & POKEMON COLLECTIBLES (CP Card)

1. Política de Privacidad

Basado en `politica-privacidad.html` de tu proyecto. Resume qué datos recopila tu sitio y dónde se guardan.

Dónde se guardan: los datos de cuenta, pedidos, reseñas, favoritos y eventos se almacenan en la base de datos MySQL del hosting, y los eventos de analítica y el carrito se guardan además en el navegador (localStorage), bajo las claves `cp-card-eventos` y `sumire-carrito`. La contraseña nunca se guarda en texto plano: se almacena su hash bcrypt. Y lo más importante para la privacidad: el número de tarjeta no se guarda en ningún sitio, porque en la pasarela sandbox se

2. Términos de Servicio

Resume las condiciones de uso de tu sitio, y aclara si tu pago es real o una simulación educativa.

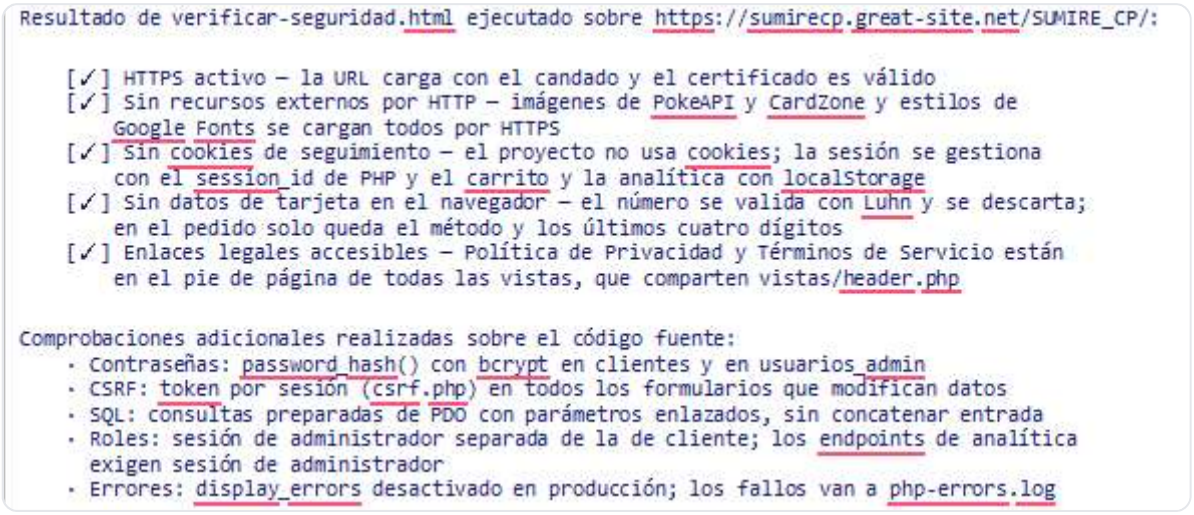
explícita en su pie de página y en la página de términos que el cobro con tarjeta es una simulación.
Y para que quede inequívoco: el pago con tarjeta de este proyecto es una simulación educativa, no un cobro real. No hay transferencia de fondos, no se piden datos bancarios reales y el sandbox acepta únicamente los números de tarjeta de prueba publicados por Stripe. Los pagos

3. Verificación de seguridad básica

Ejecuta verificar-seguridad.html sobre tu sitio ya publicado y marca lo que aplique.

- [x] El sitio se sirve por HTTPS (candado en el navegador).
- [x] No se detectaron recursos externos cargados por HTTP sin cifrar.
- [x] El sitio no usa cookies (o, si las usa, están declaradas en la Política de Privacidad).
- [x] Ningún dato de tarjeta se guarda en localStorage ni se envía a un servidor.
- [x] Los enlaces legales (privacidad/términos) son accesibles desde cualquier página del sitio.

4. Evidencia (captura de verificar-seguridad.html sobre tu sitio publicado)



```
Resultado de verificar-seguridad.html ejecutado sobre https://sumirecp.great-site.net/SUMIRE_CP/:

    [✓] HTTPS activo — la URL carga con el candado y el certificado es válido
    [✓] Sin recursos externos por HTTP — imágenes de PokeAPI y CardZone y estilos de
        Google Fonts se cargan todos por HTTPS
    [✓] Sin cookies de seguimiento — el proyecto no usa cookies; la sesión se gestiona
        con el session_id de PHP y el carrito y la analítica con localStorage
    [✓] Sin datos de tarjeta en el navegador — el número se valida con Luhn y se descarta;
        en el pedido solo queda el método y los últimos cuatro dígitos
    [✓] Enlaces legales accesibles — Política de Privacidad y Términos de Servicio están
        en el pie de página de todas las vistas, que comparten vistas/header.php

Comprobaciones adicionales realizadas sobre el código fuente:
    · Contraseñas: password_hash() con bcrypt en clientes y en usuarios_admin
    · CSRF: token por sesión (csrf.php) en todos los formularios que modifican datos
    · SQL: consultas preparadas de PDO con parámetros enlazados, sin concatenar entrada
    · Roles: sesión de administrador separada de la de cliente; los endpoints de analítica
      exigen sesión de administrador
    · Errores: display_errors desactivado en producción; los fallos van a php-errors.log
```

5. Aspectos éticos considerados

¿Tu sitio es honesto con el usuario sobre lo que hace? (ej. que el pago es una simulación, que el chatbot puede no saber todo, que los datos son solo locales)

datos: la política de privacidad indica qué se guarda, dónde y por qué, y que los eventos de analítica se acumulan en el servidor para mejorar el negocio.
Hay un cuarto punto que conviene señalar por honestidad: las reseñas del sitio solo puede dejarlas quien tiene un pedido en estado Pagado, Entregado, Por entregar o Por verificar. Es una verificación de compra real, no una decoración, y evita que las reseñas se conviertan en

6. Conclusión

en la práctica como un catálogo y un gestor de pedidos verificados, no como un procesador de pagos, y decirlo con claridad evita confusiones y sorpresas innecesarias.
El trabajo de seguridad no termina aquí: cuando se conecte la pasarela real habrá que revisar el tratamiento de los datos de la tarjeta según la normativa que aplique, y el RUC del cliente en las ventas corporativas tendrá que guardarse cifrado y con acceso restringido al administrador. La base actual ya está preparada para eso: la separación de sesiones entre cliente y administrador

> **Nota:** cumplir con estos puntos no reemplaza una asesoría legal real si el proyecto pasa a producción con datos y pagos reales; es la base mínima honesta para un proyecto educativo publicado.